Anexo B — Matriz de riesgos

14 riesgos con control del SOC y fase de implementación

Caso	C23 — TalentoRemoto Staffing TI S.A.S. (empresa ficticia, 10 empleados, 20 equipos)
Consultor(es)	Angel David Rey Duran
Programa / institución	Ingeniería de Sistemas — Unidades Tecnológicas de Santander
Versión / fecha	

Matriz de **14 riesgos** (mínimo exigido: 10) relacionados con el giro y el riesgo particular del caso C23: trabajo 100 % remoto, redes domésticas, credenciales robadas y equipos fuera de control. Probabilidad (P) e impacto (I) en escala 1–5; **Nivel = P × I**.

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-01	Robo de credenciales por infostealer en portátil de consultor	PC/MAC/UBU (A-01…A-16)	4	5	20 (Crítico)	Kaspersky EDR con alerta a Wazuh (regla 100310); PB-02; MFA recomendado	SOC N1	3
R-02	Inicio de sesión VPN con credenciales robadas desde país inusual	SRV-C23-VPN, identidades	4	5	20 (Crítico)	Regla de IP/país no autorizado (100300); PB-04; revisión de sesiones; MFA	SOC N1	2
R-03	Agente de seguridad detenido o manipulado en un portátil (evasión de controles)	Endpoints remotos	3	4	12 (Alto)	Alerta de agente detenido/desconectado (100320); contraseña de protección del agente; PB-04 y ticket	SOC N1	2, 3
R-04	Red doméstica insegura (router con claves por defecto, Wi-Fi débil)	Todos los equipos de usuario	5	3	15 (Alto)	VPN obligatoria, SCA de endpoint, guía de buenas prácticas en la base de conocimiento de GLPI	Admin. TI	2, 4
R-05	Phishing dirigido a consultores y credenciales de Microsoft 365	M365, identidades	4	4	16 (Alto)	PB-06, buzón de reporte con ticket en GLPI, bloqueo de dominios en NGFW	SOC N1	6
R-06	Equipos fuera de control: sin parches ni vulnerabilidades corregidas	Endpoints remotos	4	3	12 (Alto)	Módulo de vulnerabilidades de Wazuh, PB-09, inventario con GLPI Agent	Admin. TI	2, 4
R-07	Pérdida o robo de portátil con datos de clientes	Portátiles	3	4	12 (Alto)	Inventario, cifrado de disco (política), procedimiento de ticket y revocación de accesos	Admin. TI	4, 6
R-08	Fuga de datos personales (hojas de vida, Ley 1581)	WS-C23-02, M365	3	5	15 (Alto)	Clasificación de la información, FIM en rutas de RR. HH., control de USB (Kaspersky), PB-05	Responsable SOC	0, 3
R-09	Compromiso de cuenta privilegiada (identidad / administración M365)	SRV-C23-AD, M365	2	5	10 (Alto)	PB-08 (cuenta privilegiada nueva), reglas de eventos de membresía, escalamiento inmediato a N2	Responsable SOC	2, 6
R-10	Fuerza bruta contra el servidor de VPN/gateway expuesto	SRV-C23-VPN	4	4	16 (Alto)	Reglas de autenticación de Wazuh y active response (firewall-drop); PB-01	SOC N1	2
R-11	Alertas sin atender por falta de proceso o de personal en turnos	SOC N1	3	4	12 (Alto)	Manual del SOC, SLAs, playbooks, turnos y guardias, KPIs	Responsable SOC	6

R-12	Incumplimiento de confidencialidad contractual con clientes	Accesos a clientes	2	5	10 (Alto)	Registro de accesos, PB-04, informes de incidente y notificaciones definidas	Gerencia	6

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-13	Indisponibilidad de la VPN (caída o ataque de denegación)	SRV-C23-VPN, NGFW	3	4	12 (Alto)	Monitoreo de disponibilidad del servicio, respaldo de configuración, NGFW con VPN redundante (cotización)	Admin. TI	1, 5
R-14	Uso de dispositivos USB o equipos personales sin autorización (shadow IT)	Endpoints	3	3	9 (Medio)	Control de dispositivos de Kaspersky, PB-05, política de uso aceptable	Admin. TI	3

Escalas: 1–4 Bajo · 5–9 Medio · 10–16 Alto · 17–25 Crítico. P: 1 Rara, 2 Improbable, 3 Posible, 4 Probable, 5 Casi segura. I: 1 Insignificante, 2 Menor, 3 Moderado, 4 Mayor, 5 Crítico. Las calificaciones son una propuesta inicial del equipo y deben revisarse y justificarse en la sustentación.